

Инцидент №1

1. Уровень критичности

Высокий. Учётная запись не обладает административными правами в ИТ, но имеет обширные права доступа (не исключено, что излишние):

- это руководитель — от его имени можно создавать, согласовывать документы;
- доступ к управлению выплатами зарплаты (1С ЗУП);
- доступ к управлению договорами, внутренними документами (1С Документооборот);
- сетевой доступ во внутренний контур через VPN (vpn-default, vpn-common-services)
- доступ к файловым серверам (gg_fserv_*);
- состоит в группе GG_proxy_exclude — трафик идёт в обход прокси-сервера, то есть в обход веб-фильтрации, DLP-системы

Доступ к коммерческой, кадровой информации, доступ во внутр. контур через VPN, возможность обхода средств анализа трафика — назначаю уровень «Высокий». Назначил бы уровень «критический», если бы был доступ (возможно, не прямой) к инфраструктуре.

2. Возможные последствия компрометации

- компрометация деловой переписки
- рассылка внутреннего фишинга или вредоносного ПО от имени руководителя
- мошенничество в процессах открытия объектов: подложные счета, влияние на выбор подрядчиков, условия аренды; согласование документов в 1С Документооборот от лица руководителя.
- доступ к перс. данным, зарплатным данным через 1С ЗУП.
- Доступ к файловым серверам, облачным хранилищам: проектная документация, планы помещений, коммерческие условия.
- Разведка, сканирование внутреннего контура, будучи подключённым в VPN.
- Эксфильтрация информации за счёт членства в GG_proxy_exclude.

3. Приоритет реагирования

- Немедленная реакция: требуется (блокировка учётной записи, завершение сессий).
- Привлечение ИТ-службы: да — блокировка, разбор VPN- и почтовых сессий, проверка наличия двухфакторной аутентификации.
- Уведомление руководства: да — руководство УК и служба ИБ; при подтверждении доступа к 1С ЗУП привлекаются HR и юридическая служба.
- Расследование: требуется.

4. Срок устранения

Мероприятие	Срок
Блокировка учётной записи	немедленно
Завершение сессий, разрыв подключений	до 30 минут
Смена пароля	до 30 минут
Проверка, сброс изменений 2FA	до 1 часа
Анализ журналов (VPN-сервер, почтовый сервер, ПО 1С, прокси-сервер)	до 4 часов
Проверка почтовых сообщений	до 1 рабочего дня
Ревизия членства в группах (proxy_exclude, fserv)	до 2 рабочих дней
Полное расследование	до 3 рабочих дней

5. Рекомендации по предотвращению повторения

- Обязательная MFA на всех точках входа: VPN, почта, Yandex 360, 1С.
- Пересмотр членства GG_proxy_exclude: исключения из прокси ослабляют контроль утечек, их следует свести к минимуму и обосновать по каждому пользователю.
- Ревизия членства в группах файловых серверов по принципу наименьших привилегий.
- Отдельный трек антифишингового обучения для руководителей (защита от целевого фишинга).
- Мониторинг аномалий входа по VPN и почте (новые устройства, нетипичная геолокация).

Инцидент №2

1. Уровень критичности

Критический. Отсутствие прав (заданных явно) администратора домена ещё не означает, что по факту прав нет: имеющийся набор доступа позволяет иметь контроль над инфраструктурой:

- доступ администратора к серверам через RDS — контроль над терминальными серверами; над пользовательскими данными, обрабатываемыми этими серверами.
- доступ к vCenter — управление инфраструктурой (резервные снимки дисков с данными, настройка сетей, изменение параметров и состояний вирт. машин);
- доступ к Vault — сервисные учётные данные (credentials), ключи;
- права на перезапуск контейнеров — влияние на доступность сервисов;
- группа Disable-Pass — потенциальная возможность отключать парольную защиту и сбрасывать пароли, то есть эскалировать доступ на чужие учётные записи;
- специфика первой линии: знание процедур сброса паролей/MFA и доступ к средствам удалённого управления рабочими станциями пользователей.

2. Возможные последствия компрометации

- Компрометация терминальных серверов RDS и перехват активных пользовательских сессий.
- Управление виртуальной инфраструктурой через vCenter вплоть до снятия образов дисков с конфиденциальными данными, вывода информационных систем из строя.
- Извлечение секретов из Vault и их использование для доступа к другим сервисам (эффект «цепной реакции»).
- Доступ к GitLab (включая CI-подсистему): кража исходного кода, секретов в пайплайнах, внедрение вредоносного кода (supply chain).
- Доменная компрометация.

3. Приоритет реагирования

- Немедленная реакция: да (наивысший приоритет среди рассмотренных инцидентов).
- Привлечение ИТ-службы: да, а также отделы SOC, ИБ; администраторов инфраструктуры и владельцев vCenter, Vault, GitLab.
- Уведомление руководства: да, с эскалацией до CISO/CIO; инцидент рассматривается как потенциально крупный.
- Расследование: да, полноценное DFIR — форензика, анализ журналов RDS, VPN, vCenter, Vault, GitLab, поиск следов закрепления.

4. Срок устранения

Мероприятие	Срок
Блокировка учётной записи, всех сессий (RDS, VPN, VDI) администратора	немедленно
Изоляция задействованных рабочих станций, серверов	немедленно
Ротация секретов в Vault, к которым был доступ	до 1 часа
Ротация токенов доступа к GitLab	до 2 часов
Проверка vCenter, RDS и на новые учётные записи, изменения правил доступа	до 4 часов
Анализ журналов vCenter, RDS, VPN, Vault, GitLab	до 1 рабочего дня
Поиск следов закрепления	до 3 рабочих дней
DFIR-расследование	до 5 рабочих дней

5. Рекомендации по предотвращению повторения

- Обязательная фишинг-устойчивая двухфакторная аутентификация для всего персонала (особенно с привилегированным доступом).
- Разделение учётных записей: повседневная (подверженная фишингу) и отдельная административная, недоступная из почты и браузера.
- Пересмотр раздутого набора групп: более 60 групп у сотрудника первой линии — нарушение принципа наименьших привилегий. Переход к ролевой модели, РАМ и доступу по запросу (JIT), привилегированные действия — через bastion/PAW.
- Антифишинговое обучение.
- Мониторинг и оповещения по привилегированным действиям.

Инцидент №3

1. Уровень критичности

Низкий. Доступ ограничен почтой, ActiveSync, Яндекс 360, ЭДО Контур; доступа к более чувствительным ресурсам (VPN, файловые серверы, инфраструктура) недоступны. Существенный смягчающий фактор — членство в группах второго фактора (Контур 2FA, Kontur_MFA): при корректно настроенном MFA одной пары «логин/пароль» для входа недостаточно. Остаточный риск при этом не нулевой — почтовый ящик остаётся точкой опоры.

2. Возможные последствия компрометации

- Чтение корпоративной почты: разведка, перехват деловой переписки, сбор информации для дальнейших атак.
- Рассылка внутреннего фишинга от доверенного корпоративного адреса.
- Сброс паролей к сторонним сервисам через почтовый ящик (перехват писем восстановления доступа).
- Доступ к ЭДО Контур: складские документы и первичная документация.
- ActiveSync — устойчивый доступ к почте с мобильных устройств; атаки на утомление MFA (MFA fatigue).
- Масштаб последствий ограничен отсутствием доступа к финансам, ERP и инфраструктуре.

3. Приоритет реагирования

- Немедленная реакция: желательна, но всё-таки не наивысший приоритет — после инцидентов №1, №2.
- Привлечение ИТ-службы: да — сброс пароля, проверка зарегистрированных MFA-устройств и активных сессий.
- Уведомление руководства: в рамках штатного регламента; отдельная эскалация не требуется, если не выявлен фактический несанкционированный доступ.
- Расследование: базовое (журналы входа, регистрации MFA, почтовые правила); полномасштабное — только при признаках реального доступа злоумышленника.

4. Срок устранения

Мероприятие	Срок
Блокировка учётной записи	немедленно
Смена пароля	до 30 минут
Проверка зарегистрированных устройств	до 1 часа

Мероприятие	Срок
Анализ журналов входа (почта, Яндекс 360, Контур)	до 4 часов
Проверка почтовых правил и пересылок	до 1 рабочего дня
Базовое расследование (при необходимости)	до 3 рабочих дней

5. Рекомендации по предотвращению повторения

- Распространить двухфакторную аутентификацию на все сервисы (почта, Яндекс 360, ActiveSync), а не только на Контур.
- Ограничить устаревшие протоколы аутентификации (basic auth в ActiveSync), которые обходят второй фактор.
- Политики условного доступа по геолокации, доверенным устройствам.
- Регулярное антифишинговое обучение для линейного персонала.